BulkPay ERP — Règles de la base de données

Oct 17, 2026 · @Diomaye

Ce document liste toutes les règles à respecter pour que BulkPay ERP ne paie jamais deux fois, ne perde aucun franc et protège les données des bénéficiaires. Chaque règle a un responsable et un état. Si votre code touche à une règle, relisez-la avant de livrer.

À lire d'abord

La base de données est hébergée sur **Supabase** (PostgreSQL). Docker ne sert qu'à faire tourner le backend, qui se connecte à Supabase. Personne ne modifie la structure de la base en direct : tout passe par Assane Dione (base de données).

Légende de la colonne État

État	Signification
Fait	Déjà en place dans le dossier de la base (db)
v3	Prévu dans la prochaine version de la base
À faire	À coder par le responsable indiqué
À vérifier	Hypothèse à confirmer le premier jour en sandbox Bitnob

Règle d'or sur les secrets. Le mot de passe principal Supabase n'est partagé avec personne. Chaque membre reçoit son propre compte, avec seulement les droits dont il a besoin (voir « Accès à la base et secrets »).

Qui fait quoi

Personne	Partie (dossier)	Règles dont elle est responsable
Personne 1 – Assane Diakhoumpa	Backend FastAPI et Docker (`backend`)	Conteneur Docker du backend (seul composant dans Docker, la base reste sur Supabase), appels Bitnob signés, webhooks, cartes virtuelles, factures Lightning, connexion des utilisateurs, secrets dans `.env` , logs sans données sensibles
Personne 2 – Assane Dione	Base de données et tableau de bord (`db`)	Schéma, migrations, contraintes, vues, compte en lecture seule pour l'IA, journal d'audit, données de démo, contrôles avant démo, documentation du schéma
Personne 3 – Ibra Dione	Assistant IA (`ai`)	Une seule lecture par requête, vues uniquement, limites de lignes et de durée, aucune donnée personnelle, résistance aux injections
Personne 4 – Sokhna Mbathie Niang	Design et frontend (`frontend`)	Jamais de numéro de carte affiché, confirmation du total avant lancement, page de connexion
Personne 5 – Amath	GitHub, intégration continue, branchement du frontend	`.env` hors du dépôt (seul `.env.example` est commité), branches protégées, tests à chaque pull request

Chaque personne ne modifie que son dossier. Un besoin sur le dossier d'un autre passe par une issue ou une pull request.

1. L'argent

Tout montant est un nombre entier exact. On ne mélange jamais deux devises. C'est ainsi qu'on respecte le principe du document de projet (« précision suffisante pour les crypto-actifs ») : 1 satoshi ou 0,000001 USDT est représenté exactement.

Règle	Pourquoi	Responsable	État
Montants stockés en entiers, dans la plus petite unité de la devise (XOF : 0 décimale, NGN, GHS, KES, USD : 2, USDT, USDC : 6, BTC : 8)	Les nombres à virgule flottante perdent des centimes (0,1 + 0,2 ≠ 0,3)	Assane Dione	Fait
Les montants reçus de Bitnob (`"50.00"`) sont lus comme des décimaux exacts (`Decimal` en Python), jamais en `float`	Même raison	Assane Diakhoumpa	À faire
Deux devises différentes ne sont jamais additionnées. Les totaux sont donnés par devise, ou dans l'actif débité (USDT)	1 000 XOF + 1 000 NGN ne veut rien dire	Assane Dione	Fait
Arrondi vers le bas pour ce que reçoit le bénéficiaire, vers le haut pour ce qu'on débite	On ne promet jamais plus que ce qui sera versé	Assane Dione	Fait
Tant que Bitnob ne l'a pas confirmé, on considère que les frais s'ajoutent au montant	Mieux vaut surestimer le coût	Assane Dione	À vérifier
La base refuse un montant négatif ou nul et une devise inconnue	Même si le backend se trompe, la base bloque	Assane Dione	Fait
Le taux de change est stocké tel que Bitnob l'a donné, sans arrondi	Pour pouvoir recalculer et justifier chaque montant	Assane Dione	Fait

2. Les paiements

Le risque n°1 est de payer deux fois la même personne. Toutes les règles ci-dessous servent à l'éviter. Un paiement n'est « réussi » qu'à la réception du webhook de livraison Bitnob (payouts.withdrawal.success), jamais sur la seule réponse de l'API.

Parcours d'un paiement chez Bitnob : cotation (`/quotes`), puis initialisation (`/initialize`), puis finalisation (`/finalize`). Statuts chez nous : `quoted` → `initialized` → `pending` → `completed` , ou `failed` , ou `expired` .

Règle	Pourquoi	Responsable	État
Chaque paiement a une référence unique, créée et enregistrée par nous avant d'appeler Bitnob	Un double clic ou une relance ne crée pas un second paiement	Assane Dione (base), Assane Diakhoumpa (appel)	Fait
Une ligne de lot ne peut avoir qu'un seul essai réussi. Relancer un échec crée un nouvel essai, et seulement si le précédent est définitivement échoué ou expiré. Les essais ratés restent dans une table séparée	Garder la trace des échecs sans risque de doublon	Assane Dione	v3
Si Bitnob ne répond pas (délai dépassé), on demande d'abord le statut du paiement. On ne relance jamais à l'aveugle	Le paiement est peut-être déjà parti	Assane Diakhoumpa	À faire
On vérifie que la cotation n'a pas expiré (`expires_at`) avant de finaliser. Expirée = nouvelle cotation	Le taux a pu changer	Assane Diakhoumpa	Fait (fonction prête)

Règle	Pourquoi	Responsable	État
Un lot trop long pour être payé avant l'expiration des cotations est signalé avant le lancement	Éviter des dizaines de cotations expirées	Assane Dione	Fait
Un statut ne recule jamais, et un statut final (`completed` , `failed` , `expired`) ne change plus	Les webhooks arrivent parfois dans le désordre	Assane Dione	Fait (Python), v3 (la base le refuse aussi)
Chaque changement de statut est enregistré dans l'historique avec sa date	Retracer chaque paiement	Assane Dione	Fait
Un paiement échoué a toujours une raison	L'expliquer au client	Assane Dione	Fait
Un paiement en attente depuis plus de 15 minutes déclenche une alerte, puis on interroge Bitnob pour enquêter (le succès reste confirmé par le webhook)	Bitnob ne documente pas de webhook d'échec	Assane Dione (alerte), Assane Diakhoumpa (interrogation)	Fait (alerte)
Un lot partiellement réussi a le statut `partial` , avec la liste des lignes échouées	Ne jamais afficher « terminé » si tout n'est pas payé	Assane Dione	Fait

3. Les enveloppes budgétaires et les cartes virtuelles

Chaque enveloppe (par exemple « Meta Ads – 100 USD par mois ») a sa propre carte virtuelle Bitnob, prépayée, en USD et utilisable en ligne. Le budget est donc un vrai solde chez Bitnob, et la base doit toujours lui correspondre.

Règle	Pourquoi	Responsable	État
Le numéro complet de la carte, le CVV et la date d'expiration ne sont jamais stockés, affichés ni écrits dans les logs. On garde seulement l'identifiant Bitnob de la carte et ses 4 derniers chiffres	Règles de sécurité des cartes (PCI DSS) : sans numéro stocké, rien à voler	Assane Dione (base), Assane Diakhoumpa (API)	v3
Les pièces d'identité du titulaire (KYC carte) ne sont pas stockées chez nous : seulement l'identifiant client Bitnob et le statut de vérification	Données très sensibles, déjà gardées par Bitnob	Assane Dione, Assane Diakhoumpa	v3
Montants des cartes en cents de USD (entiers)	Les cartes sont en USD	Assane Dione	v3
Le solde d'une enveloppe est calculé à partir de son journal de mouvements (financement, dépense, remboursement, rechargement), jamais saisi à la main	Un solde stocké seul peut devenir faux sans que personne ne le voie	Assane Dione	v3
Un mouvement n'est jamais modifié ni supprimé. Une erreur se corrige par un mouvement inverse	Comme en comptabilité : tout reste traçable	Assane Dione	v3
Chaque transaction de carte a un identifiant Bitnob unique : reçue deux fois, elle n'est comptée qu'une fois	Pas de double dépense	Assane Dione	v3
Une dépense refusée ne diminue pas le solde. Un remboursement l'augmente	Le solde suit la réalité	Assane Dione (règle), Assane Diakhoumpa (lecture des transactions)	v3

Règle	Pourquoi	Responsable	État
Le solde calculé de chaque enveloppe est comparé chaque jour au solde réel de sa carte chez Bitnob. Un écart déclenche une alerte	Détecter une transaction manquée	Assane Dione (contrôle), Assane Diakhoumpa (relevé)	v3
Alerte quand le solde passe sous un seuil (par exemple 10 USD), gel automatique de la carte à 0. Chaque gel et dégel est inscrit au journal d'audit	C'est le cœur du module	Assane Dione (seuils, alertes), Assane Diakhoumpa (gel)	v3
Rechargement mensuel : une seule fois par enveloppe et par mois (contrainte unique enveloppe + mois), même si la tâche planifiée tourne deux fois	Pas de double rechargement	Assane Dione (contrainte), Assane Diakhoumpa (tâche)	v3
Un financement ou un rechargement est refusé si le solde de l'entreprise chez Bitnob ne suffit pas	Pas de découvert	Assane Diakhoumpa	À faire
En sandbox, les dépenses de carte simulées sont marquées `is_simulated`	Ne jamais confondre démo et réalité	Assane Dione	v3

4. Les webhooks Bitnob

L'adresse des webhooks est publique : seule la signature de Bitnob prouve qu'un message est authentique.

Règle	Pourquoi	Responsable	État
La signature `x-bitnob-signature` (HMAC SHA512) est vérifiée sur le message brut, avant de le lire	N'importe qui peut appeler l'adresse	Assane Diakhoumpa	Fait (fonction prête)

Règle	Pourquoi	Responsable	État
Le format exact de la signature (hexadécimal ou base64) est confirmé sur un vrai webhook	La fonction accepte les deux en attendant	Assane Diakhoumpa	À vérifier
Le numéro d'événement (`event_id`) est unique : un renvoi est ignoré	Bitnob renvoie parfois le même webhook	Assane Dione	Fait
Tout webhook est enregistré, même avec une signature invalide	Pour enquêter	Assane Dione	Fait
Référence inconnue ou montant différent = alerte, jamais de mise à jour	Signe d'erreur ou de fraude	Assane Dione	Fait
On répond 200 immédiatement, le traitement se fait ensuite	Sinon Bitnob considère l'envoi raté et réessaie	Assane Diakhoumpa	À faire
Le secret qui sert à vérifier les webhooks reste dans `.env`	Avec ce secret, on peut fabriquer de faux webhooks	Assane Diakhoumpa	À faire

5. Les factures Bitcoin

Les factures passent par le réseau Lightning et s'affichent en QR code. Le montant est fixe et une facture ne sert qu'une fois.

Règle	Pourquoi	Responsable	État
Montants en satoshis (entiers) : 1 BTC = 100 000 000 sats	Pas d'arrondi possible	Assane Dione	v3
Trois états : en attente, payée, expirée. Une facture Lightning ne se paie pas partiellement	Conforme au document de projet	Assane Dione	v3

Règle	Pourquoi	Responsable	État
Chaque facture a une date d'expiration. Une facture expirée ne repasse jamais à « payée »	Une facture Lightning expirée ne peut plus être réglée	Assane Dione (base), Assane Diakhoumpa (création)	v3
L'identifiant Bitnob de la facture est unique. Elle passe à « payée » une seule fois, sur l'événement de paiement Bitnob	Pas de double encaissement	Assane Dione	v3
Le taux BTC/USD est enregistré à la création et au paiement	Justifier la contre-valeur plus tard	Assane Dione	v3
Les endpoints Lightning et le nom de l'événement de paiement sont confirmés en sandbox	Le document de projet les marque « à confirmer »	Assane Diakhoumpa	À vérifier

6. Utilisateurs, connexion et audit

Seuls les membres de l'entreprise cliente se connectent. Les bénéficiaires (livreurs, freelances) n'ont pas de compte : ils reçoivent seulement l'argent.

Choix recommandé : **Supabase Auth** pour la connexion (mot de passe, mot de passe oublié, jetons). Le backend vérifie le jeton Supabase sur chaque route. La table `users` de la base devient un profil lié au compte Supabase. Ce choix est à valider par Assane Diakhoumpa.

Règle	Pourquoi	Responsable	État
Deux rôles : **admin** (tout) et **lecteur** (voir seulement). Pour le MVP (« authentification administrateur simple »), seul le rôle admin est utilisé ; lecteur est prévu dans la base mais facultatif. Seul un admin lance un lot, gère une enveloppe ou crée une facture	Moindre privilège	Assane Dione (base), Assane Diakhoumpa (contrôle)	v3
Un compte peut être désactivé sans être supprimé	On garde l'historique de ce qu'il a fait	Assane Dione	v3
Journal d'audit jamais modifié : connexions, lancements et relances de lot, création, gel, dégel et rechargement des cartes, factures	Répondre à « qui a fait quoi, et quand ? »	Assane Dione (table), Assane Diakhoumpa (écriture)	v3
Aucun mot de passe stocké en clair (Supabase Auth s'en charge)	En cas de fuite, les mots de passe restent protégés	Assane Diakhoumpa	À faire
Toutes les routes exigent un jeton valide, sauf la connexion et les webhooks (protégés par la signature)	Personne n'entre sans compte	Assane Diakhoumpa	À faire
Le frontend redirige vers la connexion quand le backend répond 401	Session expirée gérée proprement	Sokhna Mbathie Niang et Amath	À faire
Un compte admin de démonstration existe dans les données de démo, avec un mot de passe qui n'est utilisé nulle part ailleurs	Démo sans risque	Assane Dione	v3

7. Accès à la base et secrets

Chaque programme se connecte avec son propre compte PostgreSQL, qui n'a que les droits nécessaires.

Compte	Utilisé par	Peut faire	Ne peut pas faire	État
Propriétaire	Assane Dione	Modifier la structure, uniquement par des fichiers de mise à jour	—	Fait
`app_backend`	Backend (Assane Diakhoumpa)	Lire et écrire les données	Supprimer une table, changer la structure, modifier le journal d'audit ou les mouvements d'enveloppe	v3
`ai_reader`	Assistant IA (Ibra Dione)	Lire les vues, avec une durée maximale par requête	Lire les tables, écrire quoi que ce soit	v3
`powerbi_reader`	Power BI, tableau de bord	Lire les vues	Écrire	v3
`anon`, `authenticated` (Supabase)	Personne	Rien	Lire ou écrire les tables	Fait (droits retirés), v3 (RLS en plus)

Règles sur les secrets

Règle	Responsable	État
Mots de passe, adresse de la base, clé et secret Bitnob, secret des jetons : uniquement dans `.env`	Assane Diakhoumpa	À faire
`.env` est dans `.gitignore`. Un fichier `.env.example` sans valeurs montre les variables attendues	Amath	À faire

Règle	Responsable	État
La clé secrète Bitnob reste dans le backend, jamais dans le frontend ni dans le navigateur	Assane Diakhoumpa, Sokhna Mbathie Niang et Amath	À faire
Les mots de passe des comptes sont transmis en privé, jamais dans le groupe ni sur GitHub	Assane Dione	À faire
Connexion chiffrée (SSL) obligatoire vers Supabase	Tous	Fait
Aucun secret visible sur l'écran pendant la démo (fermer `.env` et la page des paramètres Supabase)	Tous	À faire
Un secret affiché ou envoyé par erreur est changé immédiatement	Tous	Règle permanente

8. Assistant IA

L'assistant répond aux questions sur les chiffres. Il ne lance jamais rien et ne voit aucune donnée personnelle complète.

Règle	Pourquoi	Responsable	État
Connexion avec le compte `ai_reader` : lecture seule, vues uniquement	Une IA peut se tromper ou être manipulée	Assane Dione (compte), Ibra Dione (usage)	v3
Il lit les mêmes vues que le tableau de bord et Power BI	Tout le monde donne les mêmes chiffres	Assane Dione	Fait
Numéros de téléphone masqués (`••••1234`) dans tout ce qu'il lit	Données personnelles	Assane Dione	Fait (rapport bailleur), v3 (toutes les vues IA)
Chaque vue et chaque colonne ont une description en français dans la base	L'IA choisit la bonne vue et écrit des requêtes justes	Assane Dione	v3

Règle	Pourquoi	Responsable	État
Chaque question, la requête générée, l'utilisateur et l'historique de conversation sont enregistrés. La requête est affichée avec la réponse	Contrôle et démonstration	Assane Dione (table), Ibra Dione (écriture)	v3
Une seule instruction de lecture (SELECT) par requête, limitée en durée (quelques secondes) et en nombre de lignes	Une requête trop lourde ne bloque pas la base	Assane Dione (compte), Ibra Dione (limite)	v3
Le contenu de la base est traité comme des données, pas comme des ordres (un nom peut contenir « ignore tes consignes »)	Attaque par injection	Ibra Dione	À faire
L'endpoint de l'assistant exige un utilisateur connecté	Pas de fuite de chiffres à un inconnu	Assane Diakhoumpa, Ibra Dione	À faire

9. Données personnelles

Les noms et numéros de téléphone des bénéficiaires sont des données personnelles. Au Sénégal, elles sont protégées par la loi 2008-12, contrôlée par la CDP (Commission de protection des données personnelles).

Règle	Responsable	État
On ne garde que le nécessaire : nom, téléphone, opérateur, région, pays	Assane Dione	Fait
Téléphones masqués dans les rapports, les exports Excel et pour l'IA	Assane Dione	Fait
Aucun numéro complet, mot de passe ni jeton dans les logs	Assane Diakhoumpa	À faire

Règle	Responsable	État
Données de démo simulées, marquées (`is_simulated`) et annoncées par un bandeau	Assane Dione	Fait
Jamais de vrais numéros de personnes en sandbox ou en démo	Tous	Règle permanente

10. Import des fichiers CSV

Un fichier est entièrement vérifié avant qu'un seul paiement parte. Le module de validation est prêt : `role3/validation.py`.

Règle	Responsable	État
Colonnes obligatoires : nom, telephone, montant, devise, pays. Facultatives : operateur, region, reference	Assane Dione	Fait
Numéro au format international et du bon pays (un numéro nigérian n'est pas accepté pour le Sénégal)	Assane Dione	Fait
Opérateur accepté dans le pays (Sénégal : Wave, Orange Money, Free Money, Expresso)	Assane Dione	Fait
Devise qui correspond au pays, XOF sans décimale	Assane Dione	Fait
Doublons (même personne, même montant) et montants anormaux signalés	Assane Dione	Fait
Une ligne bloquée n'est jamais envoyée. Une ligne « à vérifier » attend une confirmation	Assane Diakhoumpa	À faire (appeler la validation)
L'utilisateur voit et confirme le total, frais compris, avant le lancement	Sokhna Mbathie Niang et Amath	À faire
Limites minimum et maximum par pays respectées	Assane Dione	Fait, à vérifier avec les vraies valeurs

11. Structure de la base et mises à jour

La structure ne change que par des fichiers numérotés, appliqués par Assane Dione.

Règle	Responsable	État
Toute modification passe par un fichier de mise à jour numéroté, qu'on peut relancer sans dégât	Assane Dione	Fait
Une table `schema_migrations` note les fichiers déjà appliqués. Un fichier appliqué n'est jamais modifié	Assane Dione	v3
Sauvegarde (`pg_dump`) avant chaque mise à jour	Assane Dione	Règle permanente
Une demande de nouvelle colonne ou table passe par une issue ou une pull request sur le dossier db. Toute modification du schéma est annoncée à l'équipe avant d'être fusionnée	Tous	Règle permanente
Dates stockées en UTC (`TIMESTAMPTZ`). Dakar est en UTC+0	Assane Dione	Fait
Liens entre tables (clés étrangères) partout, index sur les colonnes souvent filtrées	Assane Dione	Fait, à compléter en v3
Les noms de colonnes et de statuts du dictionnaire de données sont le contrat avec le backend : on ne les renomme pas sans prévenir	Assane Dione, Assane Diakhoumpa	Règle permanente

12. Chiffres, démo et jour 1 en sandbox

Un indicateur a une seule définition, dans les vues SQL. Le tableau de bord, Power BI, l'API et l'IA lisent tous ces mêmes vues.

Avant chaque démo

- [ ] `python scripts\check.py` affiche tous les contrôles OK (Assane Dione)
- [ ] Six heures avant la fin : gel du code de la base, rechargement des données de démo, vérification de chaque chiffre du pitch (Assane Dione)
- [ ] Les chiffres du pitch sont annoncés comme simulés s'ils le sont (toute l'équipe)

- [ ] Aucun secret visible à l'écran (toute l'équipe)
- [ ] Le CSV de démo (50 livreurs au Nigeria, au Ghana et au Sénégal) contient exactement ce que montre le scénario : deux numéros invalides signalés, et un paiement qui échoue puis réussit à la relance (Assane Dione)
- [ ] Les trois enveloppes de démo (Meta Ads, Outils, Formation) existent, et celle de Meta Ads est assez basse pour déclencher l'alerte puis le gel (Assane Dione)

Jour 1 en sandbox Bitnob : transformer les hypothèses en certitudes

1. **Carte virtuelle d'abord** : vérification d'identité du titulaire (Card KYC), création, financement, gel et dégel d'une carte. Tout le module d'enveloppes en dépend. Noter comment obtenir des transactions de test.
2. `GET /api/payouts/supported-countries` : pays réellement ouverts (Nigeria, Ghana, Sénégal pour la démo). Mettre `verified: true` dans `config/corridors.json`.
3. `GET /api/payouts/banks/{pays}` : vrais codes des banques et opérateurs.
4. `GET /api/payouts/limits` : vraies limites minimum et maximum.
5. Une vraie cotation : les frais s'ajoutent-ils au montant ? Combien de temps la cotation reste-t-elle valable ?
6. Un vrai webhook : format de la signature (hexadécimal ou base64).
7. Une facture Lightning : endpoint de création et nom de l'événement de paiement.

Responsables : Assane Diakhoumpa lance les appels, Assane Dione met à jour la configuration et les règles.